

🔒 ТЕХНИЧЕСКИЙ ПАСПОРТ И СХЕМАТИЧЕСКИЙ РАЗБОР МОДУЛЯ АВТОМАТИЗАЦИИ И ОПОВЕЩЕНИЙ (smtp.py)

Настоящий технический документ содержит исчерпывающее описание, паспорт безопасности и детальный пошаговый разбор всех трех частей модуля конфигурации почтового шлюза оповещений.

МОДУЛЬ АВТОМАТИЗАЦИИ И ОПОВЕЩЕНИЙ (smtp.py)

Модуль smtp.py осуществляет прямое взаимодействие с внешними почтовыми реле-серверами корпоративного контура, а также отвечает за безопасное сохранение конфигураций и доставку одноразовых ссылок доступа.

--- Схема асинхронного потока данных почтового шлюза ---

API-ЭНДПОИНТ (POST /api/smtp/config)

↓ JSON-пакет настроек (SmtpConfigSchema)

АСИНХРОННЫЙ КОНТУР FASTAPI (run_in_threadpool)

Изоляция синхронных операций ввода-вывода (I/O) диска от Event Loop

↓ Изолированный пул потоков

ТРАНЗАКЦИОННАЯ ЗАПИСЬ (write_config_to_env)

1. **МОДИФИКАЦИЯ:** Атомарное обновление конфигурационного файла .env на диске
2. **ОБНОВЛЕНИЕ ОКРУЖЕНИЯ:** Синхронизация переменных процесса (os.environ)
3. **КЛИНИНГ ОЗУ:** Валидация и обновление типов данных (bool/int) в utils

↓ Успешная авторизация шлюза

ВНЕШНИЙ SMTP-РЕЛЕ СЕРВЕР (Yandex / Mail.ru / Exchange)

🔒 Профиль ИБ-защиты подсистемы перезаписи конфигурации:

- **Защита от инъектов в конфигурационные файлы:** На этапе разбора Pydantic-модели внедрена жесткая очистка входящих строк методом `.strip()`. При парсинге флага TLS значение принудительно переводится в верхний регистр `.upper()` и валидируется по белому списку строк `["TRUE", "1", "YES"]`. Это полностью исключает возможность внедрения вредоносных символов переноса строк (`\n`) или инъектов скрытых переменных в операционную систему.
- **Сохранение целостности структуры метаданных:** Алгоритм построчной перезаписи `write_config_to_env` модифицирует исключительно легитимные ключи SMTP, полностью

сохраняя стороннюю разметку, пустые строки и комментарии файловой системы Linux.

- **Предотвращение синтаксического падения зависимых воркеров (Runtime Refresh):**

Обновление оперативной памяти процесса `os.environ` сопровождается принудительным приведением типов в модуле `utils`. Порт СУБД/почты приводится строго к типу `int`, а флаг безопасности — к типу `bool`. Это страхует фоновые асинхронные задачи от сбоев несовместимости типов `TypeError` после динамической перенастройки шлюза без перезапуска всей службы.

--- Подробное описание эндпоинтов почтового контура ---

- Эндпоинт сохранения параметров почтового шлюза (POST /config) Запрос принимает валидированный пакет `SmtpConfigSchema` под жестким контролем зависимости `RoleChecker(["admin"])`. Для предотвращения блокирующих дедлоков асинхронного ядра Uvicorn тяжелая дисковая операция записи выносится из Event Loop в отдельный изолированный пул потоков с помощью инструмента `run_in_threadpool`. Любые физические крахи накопителя перехватываются, логируются как [ИБ-КРАХ] с полным traceback и маскируются в безопасный плоский JSON-ответ с кодом 500.
- Эндпоинт отправки тестового алерта безопасности (POST /test-send) Маршрут доступен исключительно роли "admin". Извлекает актуальные авторизационные параметры SMTP напрямую из окружения оперативной памяти, исключая легаси-заглушки. Скрипт динамически собирает гляцевую структуру MIMEMultipart с HTML-версткой тела оповещения о готовности Production-периметра панели к эксплуатации.

--- Схема распределения криптографических протоколов доставки писем (HTML) ---

КОНТРОЛЛЕР СЕТЕВЫХ ПОРТОВ SMTP КЛИЕНТА

Условие: Порт == 465 (или
`use_ssl_direct`)

Условие: Порт == 587 (или иные порты)

Прямой SSL/TLS Канал

`aiosmtplib.SMTP(use_tls=True)`

Каскадный Апгрейд STARTTLS

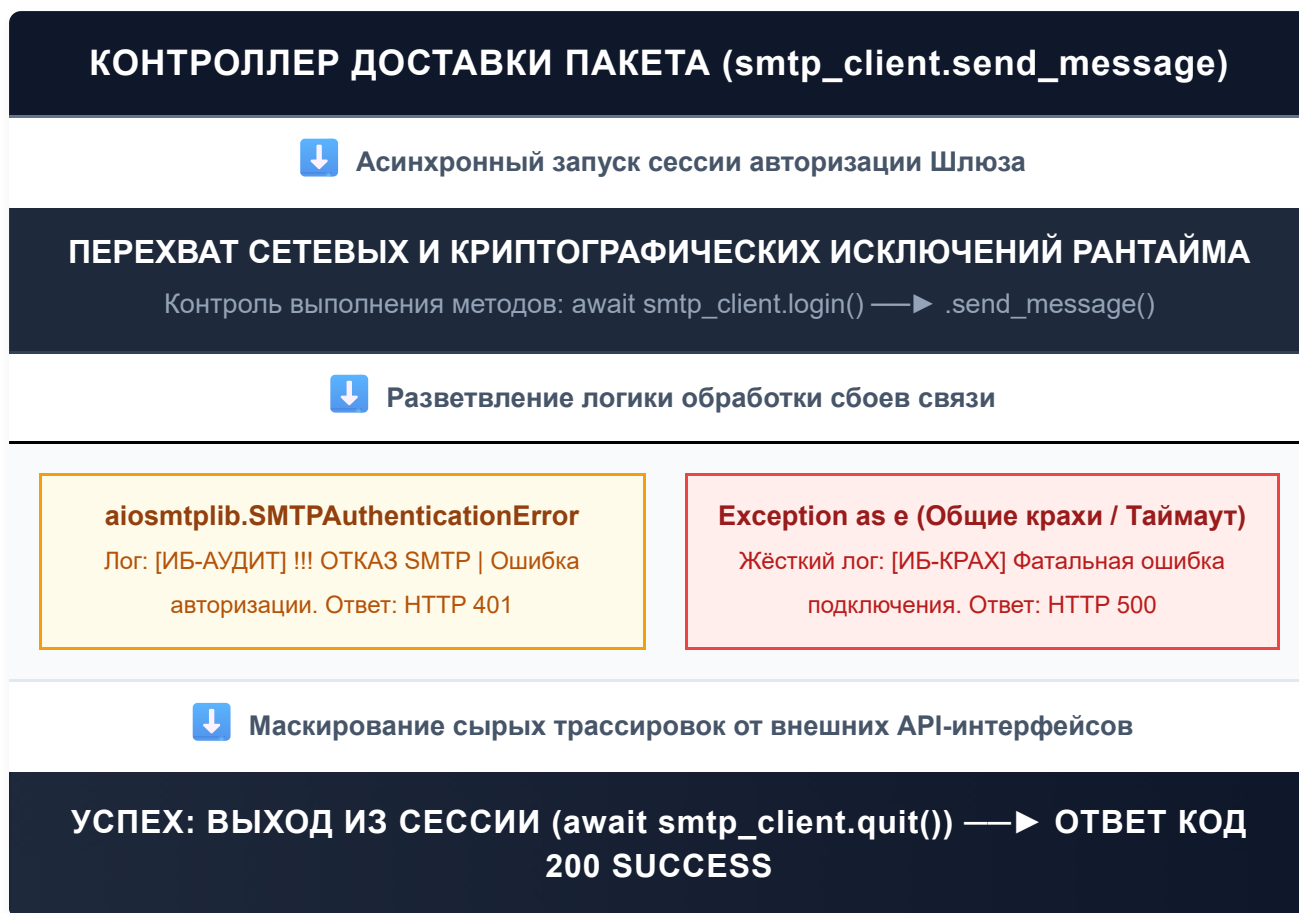
`aiosmtplib.SMTP(start_tls=True)`

Жесткий ИБ-затвор: На все асинхронные сокеты наложен лимит сессии `timeout=10` секунд

🔵 Профиль ИБ-защиты подсистемы распределения протоколов:

- **Защита от MITM-атак (Перехват сессии):** Жёсткое разделение нативного SSL и STARTTLS полностью решает проблему уязвимости «Downgrade Attack». Рантайн не пытается отправлять аутентификационные данные по открытому тексту, если порт шлюза инициализирован на защищенный корпоративный контур.
- **Лимитирование ресурсов (DoS Protection):** Параметр `timeout=10` гарантирует автоматический сброс подвисших TCP-соединений. Если удаленный шлюз выполняет скрытую Tarpit-задержку пакетов, панель не тратит ресурсы асинхронного Loop.

--- Схема сквозного ИБ-аудита и каскадной обработки ошибок ---



🛡️ Профиль ИБ-защиты подсистемы обработки ошибок почты:

- **Защита от утечки паролей приложений и учетных данных:** При сбое проверки подлинности на внешнем сервере реле, специфическое исключение `SMTPAuthenticationError` полностью перехватывается бэкэндом панели на строке 222. Журналирование инцидента в системный лог выводится в очищенном текстовом виде без раскрытия скомпрометированных секретов СУБД и паролей. Внешний клиент получает стандартизированный код `HTTP 401`.
- **Предотвращение бесконечного ожидания ответа:** На асинхронный клиент `aiosmtplib.SMTP` наложен принудительный таймаут `timeout=10` секунд. Это гарантирует, что если корпоративный или внешний почтовый сервер заблокирует сессию панели, рабочий поток `uvicorn` не зависнет в рантайме и вовремя освободит выделенные ресурсы памяти.
- **Маскирование внутренней топологии сети:** Любые иные ошибки сокетов, отказы DNS-серверов или просадки сетевых шлюзов изолируются в общий блок `except Exception`. Подробная трассировка стека пишется исключительно в защищенный локальный журнал РЕД ОС / CentOS с тегом `[ИБ-КРАХ]`, защищая архитектуру корпоративного периметра от внешней разведки.